

Diseño e Implementación de un Sistema SIEM para Análisis Automatizado de Registros de Seguridad

Universidad Tecnológica Nacional - FRM

Autor: Gianfranco Guzman, Alexander Filchel

Tutor de tesis: Ariel Enferrel y Alberto Cortez

Línea de Investigación: Ciberseguridad, Monitoreo de Seguridad y Automatización
del Análisis de Logs

Mendoza, Argentina 2026

Resumen

En los entornos tecnológicos actuales, las infraestructuras informáticas generan grandes volúmenes de registros provenientes de sistemas operativos, aplicaciones, servicios y dispositivos de red. Estos registros constituyen una fuente central para el monitoreo de seguridad, ya que permiten reconstruir eventos, identificar comportamientos anómalos y detectar indicios de compromiso dentro de una infraestructura.

Sin embargo, el crecimiento sostenido en la cantidad, diversidad y complejidad de los logs dificulta su análisis manual y reduce la capacidad de respuesta temprana frente a incidentes. En muchos ataques, las acciones del adversario no se manifiestan como un único evento aislado, sino como una secuencia de actividades distribuidas en el tiempo que dejan rastros parciales en distintas fuentes de información.

En este contexto, los sistemas de gestión de eventos e información de seguridad (SIEM) permiten centralizar registros, correlacionar eventos procedentes de múltiples capas y generar alertas ante patrones sospechosos, constituyendo una herramienta relevante para la detección temprana y la mitigación de incidentes. No obstante, su efectividad depende de la visibilidad disponible sobre el entorno monitoreado y de la calidad de los datos recolectados.

A partir de esta problemática, el presente trabajo propone analizar las capacidades y limitaciones de un sistema SIEM frente a ataques de hacking, a partir del estudio de tres casos representativos y ampliamente documentados a nivel internacional: RENAPER, Equifax y Stuxnet. Estos casos fueron seleccionados por presentar escenarios de ataque distintos, con diferentes niveles de observabilidad y posibilidad de correlación.

Sobre esta base, se plantea como hipótesis que, de los tres incidentes considerados, al menos dos podrían haberse evitado o mitigado significativamente mediante la implementación de un SIEM, mientras que uno de ellos no sería prevenible de forma directa mediante este tipo de solución.

En Análisis automatizado de registros y detección de anomalías función de ello, se analiza el alcance de un sistema SIEM a partir de su implementación en un entorno controlado y de la evaluación comparativa de incidentes reales

Índice

Resumen	2
Índice	3
CAPÍTULO 1: Introducción	6
1.1 Contexto del problema	6
1.2 Planteamiento del problema	7
1.3 Casos de estudio seleccionados	8
1.3.1 Caso RENAPER (Argentina, 2021)	8
1.3.2 Caso Equifax (Estados Unidos, 2017)	8
1.3.3 Caso Stuxnet (2010)	9
1.3.2 Justificación de la selección de casos	9
1.4 Objetivo General	10
1.5 Objetivos Específicos	10
1.6 Alcances y Limitaciones	11
1.6.1 Alcances	11
1.6.2 Limitaciones	12
1.7 Preguntas de Investigación	12
CAPÍTULO 2: Marco Teórico	13
2.1 Monitoreo de seguridad y generación de logs	13
2.2 Análisis de eventos y detección de anomalías	14
2.3 Sistemas SIEM	15
2.4 Correlación de eventos	16
2.4.1 Importancia en el monitoreo de seguridad	16
2.4.2 Ejemplos de correlación de eventos	17

2.4.3 Relación con la detección de incidentes	17
2.5 SOC y SOAR	18
2.5.1 SOAR (Security Orchestration, Automation and Response)	18
2.5.2 SOC y SecOps	18
2.6 Métricas de detección y respuesta	18
2.6.1 MTTD (Mean Time To Detect)	18
2.6.2 MTTR (Mean Time To Respond)	18
2.6.3 Relación con los sistemas SIEM	19
2.7 Estado del Arte	19
CAPÍTULO 3: Marco Metodológico	20
3.1 Tipo de investigación	20
3.2 Diseño de la investigación	21
3.3 Metodología de análisis de ataques	21
3.4 Criterios de evaluación	22
3.5 Variables de estudio	22
3.6 Instrumentos	23
CAPITULO 4: Implementación SIEM	24
4.1 Arquitectura Propuesta e Implementada	24
4.1.1 Descripción General	24
4.1.2 Componentes y Sus Roles	25
4.1.3 Red Docker y Aislamiento	26
4.1.4 Flujo de Datos del Sistema	26
4.2 Implementación Técnica	27
4.2.1 Infraestructura Docker	27
4.2.2 Pipeline de Ingesta: syslog-ng y Logstash	27
4.2.3 Almacenamiento de Eventos	28
4.2.4 Automatización y Detección de Eventos	29
4.2.5 Visualización de Eventos y Métricas	29
CAPÍTULO 5: Análisis de los casos	30
5.1 Caso 1: RENAPER (Argentina, 2021)	30
5.1.1 Descripción técnica del ataque	30

5.1.2 Timeline del ataque	31
5.1.3 Eventos generados (logs)	31
5.1.4 Análisis de detección	32
5.1.5 Detección mediante SIEM.....	32
5.1.6 Evaluación del caso	33
5.2 Caso 2: Equifax (Estados Unidos, 2017)	33
5.2.1 Descripción técnica del ataque	33
5.2.2 Timeline del ataque	34
5.2.3 Eventos generados (logs)	34
5.2.4 Análisis de detección	35
5.2.5 Detección mediante SIEM.....	35
5.2.6 Evaluación del caso	36
5.3 Caso 3: Stuxnet (2010).....	36
5.3.1 Descripción técnica del ataque	36
5.3.2 Timeline del ataque	37
5.3.3 Eventos generados (logs)	37
5.3.4 Análisis de detección	38
5.3.5 Detección mediante SIEM.....	38
5.3.6 Evaluación del caso	39
6.2 Metodología de simulación	40
6.3 Métricas Operativas	41
6.4 Resultados de la simulación	42
6.4.1 Caso RENAPER	42
6.4.2 Caso Equifax.....	43
6.4.3 Caso Stuxnet	44
6.5 Tabla comparativa de resultados	45
6.6 Análisis de resultados.....	45
CAPÍTULO 7: Conclusiones y trabajos futuros	47
7.1 Conclusiones.....	47
7.2 Validación final de la hipótesis	49
7.3 Limitaciones del trabajo.....	50

7.4 Trabajos futuros	51
7.5. Consideraciones Éticas	51
16. Referencias	52
Anexo A — Esquema SQL (Base de Datos).....	53
Anexo B — Cronograma de Implementación	57
Anexo C — Implementación del flujo automatizado en n8n	57
Anexo A.1. Nodo Cronómetro 5 min	58
Anexo A.2. Nodo GetRules.....	58
Anexo A.3. Nodo Read Logs	58
Anexo A.4. Nodo Extract from File	59
Anexo A.5. Nodo Parse Logs	59
Anexo A.6. Nodo Apply rules	60
Anexo A.7. Nodo Send an Email	61
Anexo A.8. Nodo Store alerts	62
Anexo A.9. Consideración general sobre el flujo	63

CAPÍTULO 1: Introducción

Este capítulo define el contexto técnico del trabajo, el problema asociado al análisis de registros de seguridad y el enfoque adoptado para evaluar el rol de los sistemas SIEM en la detección y mitigación de incidentes.

1.1 Contexto del problema

Los sistemas informáticos actuales producen registros de forma continua como resultado de la operación de aplicaciones, servicios, sistemas operativos y dispositivos de red. Estos eventos contienen información relevante sobre accesos, ejecuciones, comunicaciones y cambios de estado dentro de la infraestructura, por lo que constituyen la base del monitoreo de seguridad en entornos tecnológicos contemporáneos.

La utilidad de estos registros, sin embargo, no depende únicamente de su existencia, sino de la capacidad de recolectarlos, organizarlos y analizarlos de manera coherente. En este sentido, las arquitecturas SIEM permiten centralizar eventos provenientes de múltiples fuentes, normalizar la información disponible y aplicar mecanismos de correlación orientados a identificar comportamientos sospechosos que, analizados de manera aislada, podrían pasar inadvertidos.

Este enfoque resulta particularmente relevante en escenarios donde los ataques se desarrollan por etapas y generan evidencia distribuida en distintos tipos de logs. No obstante, la eficacia de un SIEM se encuentra condicionada por la visibilidad efectiva del entorno monitoreado, por la disponibilidad de registros suficientes y por la capacidad de procesar información heterogénea en tiempo oportuno.

1.2 Planteamiento del problema

En los últimos años se han registrado incidentes de ciberseguridad de alto impacto que evidencian tanto la necesidad de mejorar los mecanismos de monitoreo como los límites de las estrategias tradicionales de detección. Entre ellos pueden identificarse tres casos representativos, reconocidos y ampliamente documentados a nivel mundial: el abuso de credenciales legítimas para acceder a información sensible, como en el caso RENAPER; la explotación de vulnerabilidades en aplicaciones expuestas con permanencia prolongada dentro de la infraestructura, como en Equifax; y los ataques dirigidos a entornos industriales con afectación de procesos físicos, como Stuxnet.

Los dos primeros casos presentan acciones observables a través de registros de autenticación, aplicación, red, sistema o base de datos. En ellos, la actividad del atacante deja rastros que podrían ser centralizados y correlacionados para detectar patrones de comportamiento anómalo en etapas tempranas, lo que sugiere que un SIEM adecuadamente implementado podría contribuir a reducir el impacto del incidente mediante mecanismos de detección y mitigación.

En cambio, en ataques como Stuxnet, la visibilidad disponible desde fuentes tradicionales de logs resulta considerablemente menor, debido a la interacción con sistemas industriales específicos y a la limitada exposición de eventos críticos dentro de entornos IT convencionales. Esto plantea una limitación relevante para los sistemas SIEM basados principalmente en registros tradicionales, ya que la falta de observabilidad restringe su capacidad de detección temprana.

A partir de este análisis, el problema de investigación consiste en determinar en qué medida un sistema SIEM permite detectar y mitigar ataques de hacking a través de la correlación automatizada de registros, y cuáles son sus capacidades y limitaciones frente a escenarios con distintos niveles de visibilidad, disponibilidad de eventos y posibilidad de correlación.

1.3 Casos de estudio seleccionados

1.3.1 Caso RENAPER (Argentina, 2021)

El incidente del RENAPER consistió en el uso indebido de credenciales legítimas para acceder al servicio de validación del Sistema de Identidad Digital (SID), el cual permite consultar información personal asociada a un DNI, incluyendo datos e imagen. Las consultas se realizaron desde una conexión VPN autorizada en un período acotado de tiempo.

Si bien no se trató de una intrusión ni de una filtración masiva confirmada, el ataque evidenció un uso anómalo del sistema mediante consultas repetitivas a información sensible. Esto permitió la exposición pública de datos de distintos individuos.

1.3.2 Caso Equifax (Estados Unidos, 2017)

El incidente de Equifax se originó a partir de la explotación de una vulnerabilidad en una aplicación web basada en Apache Struts. A partir de este acceso inicial, los atacantes lograron ejecutar comandos, obtener credenciales internas y moverse lateralmente dentro de la infraestructura.

El ataque se mantuvo activo durante aproximadamente 76 días, permitiendo el acceso a bases de datos que contenían información personal de aproximadamente 147 millones de personas, incluyendo datos altamente sensibles.

1.3.3 Caso Stuxnet (2010)

Stuxnet fue un malware diseñado para atacar sistemas industriales, específicamente instalaciones de enriquecimiento de uranio en Irán. El código se propagaba a través de distintos vectores y, una vez dentro del sistema objetivo, identificaba entornos específicos para activar su funcionamiento.

El objetivo del ataque no era la obtención de datos, sino la alteración del funcionamiento de equipos industriales mediante la manipulación de controladores programables. Además, el malware ocultaba su actividad mostrando información normal a los operadores, lo que permitió prolongar su ejecución sin detección inmediata.

1.3.2 Justificación de la selección de casos

La selección de estos tres incidentes se basa en criterios técnicos orientados a evaluar el alcance de los sistemas SIEM en distintos contextos de ataque.

En primer lugar, los casos presentan diferentes vectores de ataque: abuso de credenciales (RENAPER), explotación de vulnerabilidades en aplicaciones web (Equifax) y malware dirigido a entornos industriales (Stuxnet). Esta diversidad permite analizar el comportamiento de un SIEM frente a escenarios con distintas superficies de detección.

En segundo lugar, los tres incidentes cuentan con documentación suficiente para reconstruir la secuencia de eventos, lo que permite identificar puntos específicos donde se generan logs relevantes (accesos a sistemas, consultas a bases de datos, ejecución de procesos, actividad de red), fundamentales para evaluar la capacidad de correlación de eventos.

Finalmente, la combinación de estos casos permite establecer una comparación entre escenarios donde la actividad del atacante es observable a través de registros tradicionales de IT, y otros donde la visibilidad es limitada o depende de entornos especializados, lo que resulta clave para analizar tanto el potencial como las limitaciones de un sistema SIEM.

1.4 Objetivo General

Diseñar e implementar una arquitectura de monitoreo de seguridad basada en el análisis automatizado de registros, que permita centralizar, procesar y correlacionar eventos provenientes de distintas fuentes, con el propósito de evaluar su capacidad para identificar señales tempranas de ataque y contribuir a la detección y mitigación de incidentes mediante el análisis de casos reales de ciberseguridad.

1.5 Objetivos Específicos

- Implementar un sistema de recolección centralizada de registros utilizando syslog-ng, capaz de recibir y concentrar logs provenientes de diferentes sistemas y servicios dentro de la infraestructura monitoreada.
- Procesar y normalizar los registros recolectados mediante Logstash, con el objetivo de estructurar los eventos y facilitar su análisis y correlación.
- Almacenar y organizar los eventos de seguridad utilizando Elasticsearch para la indexación y búsqueda de logs, y PostgreSQL para el almacenamiento estructurado de alertas y eventos detectados.
- Diseñar e implementar reglas de detección capaces de identificar patrones asociados a incidentes de seguridad, tales como intentos fallidos de autenticación, posibles ataques a servicios web, escaneos de directorios y otras actividades sospechosas.

- Desarrollar flujos de análisis y automatización mediante n8n que permitan evaluar los eventos registrados, generar alertas ante comportamientos anómalos y ejecutar acciones de respuesta automática, como el bloqueo de direcciones IP maliciosas.
 - Implementar mecanismos de visualización y análisis de la actividad de seguridad mediante una aplicación web, con el fin de facilitar la observación de eventos detectados y el seguimiento del comportamiento de la infraestructura monitoreada.
 - Analizar los eventos generados en los casos de estudio seleccionados, identificando puntos dentro del flujo de ataque donde podrían haberse detectado actividades sospechosas mediante la correlación de logs.
 - Evaluar en qué medida la arquitectura SIEM implementada permite detectar patrones presentes en los casos analizados y contribuir a la mitigación de incidentes de seguridad.
-

1.6 Alcances y Limitaciones

1.6.1 Alcances

El proyecto contempla el diseño, implementación y validación de una arquitectura de monitoreo de seguridad orientada al análisis automatizado de registros en un entorno de laboratorio controlado.

El sistema desarrollado permite la recolección centralizada de logs mediante syslog-ng, recibiendo eventos generados por distintos sistemas y servicios dentro de la infraestructura monitoreada. Los registros recolectados son posteriormente procesados y normalizados mediante Logstash, lo que permite extraer información relevante de los eventos y prepararlos para su análisis.

Los eventos procesados son almacenados en Elasticsearch, permitiendo realizar búsquedas y consultas eficientes sobre grandes volúmenes de registros. De forma complementaria, las alertas generadas por el sistema son registradas en PostgreSQL, lo que permite mantener un almacenamiento estructurado de los incidentes detectados.

El sistema incorpora mecanismos de análisis automatizado de eventos mediante flujos implementados en n8n, los cuales permiten aplicar reglas de detección sobre los registros procesados y generar alertas ante comportamientos sospechosos, como intentos fallidos de autenticación o patrones asociados a posibles ataques.

Finalmente, la arquitectura incluye mecanismos de visualización de eventos y métricas de seguridad mediante un dashborad interactivo que permite observar la actividad del sistema, analizar eventos detectados y facilitar el monitoreo general de la infraestructura.

1.6.2 Limitaciones

El sistema desarrollado presenta ciertas limitaciones que deben considerarse al interpretar los resultados obtenidos.

En primer lugar, el sistema utiliza **reglas de detección basadas en patrones**, por lo que no se incorporan técnicas avanzadas de detección de anomalías basadas en inteligencia artificial o aprendizaje automático.

En segundo lugar, el entorno de prueba corresponde a un **laboratorio controlado**, por lo que el comportamiento del sistema puede diferir respecto a entornos de producción con infraestructuras más complejas y mayores volúmenes de eventos.

Asimismo, el sistema no se integra con soluciones comerciales de seguridad como plataformas **EDR o XDR**, por lo que la detección de eventos se limita a los registros generados por los sistemas monitoreados.

Finalmente, las acciones de respuesta implementadas en el sistema se encuentran limitadas al **registro de alertas y generación de notificaciones**, sin ejecutar modificaciones directas sobre dispositivos de red o sistemas productivos.

1.7 Preguntas de Investigación

Las siguientes preguntas orientan el desarrollo del presente trabajo y permiten evaluar el funcionamiento de la arquitectura de monitoreo de seguridad implementada.

- ¿Qué tipo de eventos generados durante un ataque pueden ser detectados mediante el análisis de logs?
 - ¿En qué etapas del ciclo de un ataque es posible identificar señales tempranas a partir de la correlación de eventos?
 - ¿En qué medida una arquitectura SIEM permite reducir los tiempos de detección de incidentes de seguridad?
 - ¿Cuáles son las limitaciones de un SIEM frente a distintos tipos de ataques?
-

CAPÍTULO 2: Marco Teórico

Este capítulo presenta los conceptos teóricos que sustentan el desarrollo del trabajo, abordando la generación y análisis de logs, la correlación de eventos, el funcionamiento de los sistemas SIEM y las métricas utilizadas para evaluar su capacidad de detección y respuesta frente a incidentes de seguridad.

2.1 Monitoreo de seguridad y generación de logs

El monitoreo de seguridad se basa en la recolección y análisis de eventos generados por los distintos componentes de una infraestructura informática, con el objetivo de identificar actividades anómalas o potencialmente maliciosas.

Estos eventos son registrados en logs, los cuales constituyen la unidad básica de información para el análisis de seguridad. Un log es un registro estructurado o semi-estructurado que describe una acción o estado dentro de un sistema.

Los logs pueden originarse en diferentes fuentes, entre las que se destacan:

- Sistemas operativos, que registran eventos de autenticación, ejecución de procesos y acceso a recursos.
- Dispositivos y servicios de red, que generan información sobre conexiones, tráfico y comunicaciones.
- Aplicaciones, que registran la ejecución de funcionalidades, consultas a bases de datos y manejo de información.

Desde el punto de vista del monitoreo, estos registros presentan dos características relevantes: el alto volumen de eventos generados y la heterogeneidad en sus formatos y estructuras. Estas condiciones dificultan su análisis directo y requieren mecanismos de procesamiento que permitan normalizar y correlacionar la información para su posterior análisis

2.2 Análisis de eventos y detección de anomalías

El análisis de eventos de seguridad consiste en la interpretación de los logs generados por una infraestructura con el objetivo de identificar comportamientos anómalos o indicios de actividad maliciosa. Este análisis puede realizarse de forma manual o automatizada.

El análisis manual se basa en la revisión directa de registros por parte de un analista, lo que permite interpretar eventos en contexto, pero resulta poco escalable frente a grandes volúmenes de datos. En contraste, el análisis automatizado permite procesar grandes cantidades de eventos mediante reglas de detección y lógica predefinida, facilitando la identificación de patrones relevantes en tiempo reducido.

Desde el punto de vista del análisis, pueden distinguirse dos enfoques principales: la detección basada en patrones y la detección de anomalías. El primero se apoya en reglas que identifican comportamientos conocidos, como intentos fallidos de autenticación o accesos repetitivos. El segundo se enfoca en detectar desviaciones respecto al comportamiento normal del sistema, permitiendo identificar eventos no previstos.

Sin embargo, el análisis de eventos presenta limitaciones cuando los registros se evalúan de forma aislada. Un evento individual puede no representar una amenaza, pero su correlación con otros eventos dentro de una secuencia puede evidenciar la presencia de un incidente. Por esta razón, la capacidad de correlacionar eventos provenientes de distintas fuentes resulta fundamental para mejorar la detección de amenazas.

2.3 Sistemas SIEM

Un sistema SIEM (Security Information and Event Management) es una plataforma orientada a la centralización, procesamiento y análisis de eventos de seguridad generados por múltiples componentes de una infraestructura. Su objetivo es identificar actividades sospechosas a partir del análisis conjunto de registros provenientes de distintas fuentes.

Los SIEM combinan dos enfoques:

- SIM (Security Information Management): enfocado en el almacenamiento, gestión y análisis histórico de logs.
- SEM (Security Event Management): orientado al monitoreo en tiempo real, la correlación de eventos y la generación de alertas.

Funciones principales

- Recolección de logs

Permite integrar registros provenientes de sistemas operativos, aplicaciones, dispositivos de red y otros componentes, centralizando la información en un único punto de análisis.

- Normalización de eventos

Consiste en transformar logs heterogéneos en un formato estructurado común, facilitando su procesamiento y comparación.

- Correlación de eventos

Permite relacionar eventos provenientes de distintas fuentes para identificar patrones de comportamiento que no serían detectables de forma aislada.

- Generación de alertas

A partir de reglas de detección, el sistema identifica actividades anómalas y genera alertas para su análisis o respuesta.

Dentro de una arquitectura de seguridad, el SIEM actúa como una capa central de análisis que integra información de múltiples fuentes y permite mejorar la visibilidad sobre los eventos generados en la infraestructura. Su uso facilita la

detección temprana de incidentes y el seguimiento de actividades sospechosas mediante el análisis continuo de logs.

2.4 Correlación de eventos

La correlación de eventos es el proceso mediante el cual se relacionan múltiples registros provenientes de distintas fuentes con el objetivo de identificar patrones de comportamiento que puedan indicar la presencia de un incidente de seguridad.

A diferencia del análisis aislado de eventos, la correlación permite interpretar una secuencia de acciones dentro de un contexto, facilitando la detección de actividades complejas que no serían evidentes a partir de un único log.

Este proceso consiste en agrupar y analizar eventos que, aunque individuales, forman parte de una misma actividad o flujo de ataque, utilizando atributos comunes como direcciones IP, usuarios, timestamps o tipos de operación. A partir de esta relación, es posible reconstruir la secuencia de eventos y detectar comportamientos que responden a patrones específicos, permitiendo identificar actividades anómalas que solo se evidencian al analizar múltiples eventos en conjunto.

2.4.1 Importancia en el monitoreo de seguridad

La correlación de eventos es fundamental para la detección de incidentes debido a que muchos ataques se desarrollan en múltiples etapas. Cada una de estas etapas puede generar eventos que, de forma aislada, no representan una amenaza significativa.

Sin embargo, al ser analizados en conjunto, estos eventos pueden evidenciar actividades maliciosas. En este sentido, la correlación permite reducir falsos negativos y mejorar la capacidad de detección temprana dentro de una infraestructura.

2.4.2 Ejemplos de correlación de eventos

- **Autenticación + acceso a datos**

Un intento de inicio de sesión seguido de múltiples consultas a una base de datos puede indicar el uso indebido de credenciales o la extracción de información.

- **Actividad de red + ejecución de procesos**

La presencia de tráfico anómalo combinada con la ejecución de comandos en un sistema puede reflejar la explotación de una vulnerabilidad o la ejecución de código remoto.

- **Eventos repetitivos en ventana de tiempo**

Múltiples eventos similares en un intervalo corto, como intentos fallidos de autenticación o accesos consecutivos a un servicio, pueden indicar comportamientos automatizados o ataques de fuerza bruta.

2.4.3 Relación con la detección de incidentes

La capacidad de correlacionar eventos permite identificar señales tempranas dentro del flujo de un ataque, lo que resulta clave para su detección en etapas iniciales.

En escenarios donde las acciones del atacante generan múltiples eventos observables —como accesos a servicios, consultas a sistemas o transferencias de datos—, la correlación permite detectar patrones anómalos y activar mecanismos de respuesta.

Por el contrario, en entornos donde la visibilidad es limitada o los eventos no son fácilmente correlacionables, la efectividad de este enfoque se reduce, lo que impacta directamente en la capacidad de detección.

2.5 SOC y SOAR

2.5.1 SOAR (Security Orchestration, Automation and Response)

Los sistemas **SOAR (Security Orchestration, Automation and Response)** permiten automatizar procesos de análisis y respuesta ante incidentes de seguridad mediante la ejecución de **playbooks** o flujos de acciones predefinidas.

En este proyecto, la automatización se implementa mediante **n8n**, que actúa como una capa de orquestación capaz de procesar eventos, aplicar lógica condicional y ejecutar acciones automáticas como el registro de alertas o el bloqueo de direcciones IP maliciosas.

2.5.2 SOC y SecOps

Un **Security Operations Center (SOC)** es la unidad encargada de monitorear, detectar e investigar incidentes de seguridad dentro de una infraestructura informática. En este entorno, los analistas utilizan plataformas SIEM y herramientas de monitoreo para supervisar continuamente la actividad de los sistemas.

2.6 Métricas de detección y respuesta

2.6.1 MTTD (Mean Time To Detect)

El MTTD (Mean Time To Detect) es una métrica que representa el tiempo promedio que transcurre desde que ocurre un evento de seguridad hasta que es detectado por el sistema o por un analista.

Un valor bajo de MTTD indica una mayor capacidad de detección temprana, permitiendo identificar incidentes en sus etapas iniciales y reducir su impacto.

2.6.2 MTTR (Mean Time To Respond)

El MTTR (Mean Time To Respond) mide el tiempo promedio necesario para ejecutar una acción de respuesta una vez que un incidente ha sido detectado.

Esta métrica refleja la capacidad operativa para contener o mitigar un ataque, ya sea mediante acciones manuales o automatizadas.

2.6.3 Relación con los sistemas SIEM

La efectividad de un sistema SIEM puede evaluarse en función de su capacidad para reducir los tiempos de detección y respuesta ante incidentes de seguridad.

Mediante la centralización de logs, la correlación de eventos y la generación de alertas en tiempo real, un SIEM permite identificar patrones anómalos de forma más rápida que los métodos de análisis manual.

En este sentido, la reducción del MTTD y del MTTR constituye un indicador clave del impacto que tiene la implementación de este tipo de sistemas dentro de una arquitectura de monitoreo de seguridad.

2.7 Estado del Arte

El desarrollo de sistemas de monitoreo de seguridad basados en el análisis de registros ha sido ampliamente abordado en la literatura de ciberseguridad. Diversos estudios coinciden en que el aumento del volumen y la complejidad de los eventos generados por sistemas, aplicaciones y dispositivos de red ha convertido a la centralización de logs en un componente clave para la detección de incidentes.

En este contexto, los sistemas SIEM surgen como una solución orientada a recolectar, normalizar y correlacionar eventos provenientes de múltiples fuentes. De acuerdo con Bezas y Filippidou (2023), un SIEM permite integrar funciones de almacenamiento histórico y monitoreo en tiempo real, facilitando la identificación de amenazas de seguridad.

Distintos trabajos también destacan la necesidad de automatizar el análisis de registros frente a las limitaciones del procesamiento manual. Xu et al. (2009) proponen técnicas para la detección de anomalías a partir del análisis de logs, demostrando que los patrones de comportamiento pueden utilizarse para identificar fallas y eventos anómalos en sistemas distribuidos. De manera similar,

Du et al. (2017) presentan enfoques basados en aprendizaje automático para el análisis de secuencias de logs, mejorando la capacidad de detección de eventos inusuales en entornos complejos.

Asimismo, estudios sobre arquitecturas SIEM modernas señalan la importancia de la correlación de eventos como mecanismo para identificar incidentes que no serían detectables a partir de logs individuales. En este sentido, trabajos como el de Behl y Behl (2017) destacan que la correlación entre múltiples fuentes de datos permite mejorar significativamente la detección de amenazas avanzadas.

Por otro lado, la literatura resalta el rol de la automatización en entornos SOC, donde la incorporación de herramientas de orquestación permite reducir los tiempos de detección y respuesta ante incidentes, mejorando la eficiencia operativa.

En conjunto, estos trabajos evidencian una evolución hacia sistemas de monitoreo basados en la centralización, correlación y automatización de eventos. Sin embargo, la mayoría de las investigaciones se enfocan en la detección de amenazas, sin analizar en profundidad el alcance de estos sistemas en la prevención o mitigación de incidentes reales, lo que motiva el presente estudio.

CAPÍTULO 3: Marco Metodológico

Este capítulo describe el enfoque metodológico adoptado para el desarrollo del sistema de monitoreo de seguridad y el análisis de los casos de estudio, con el objetivo de evaluar el alcance de una arquitectura SIEM en la detección y mitigación de incidentes.

3.1 Tipo de investigación

El presente trabajo se enmarca en una investigación de tipo aplicada, ya que propone el diseño e implementación de una solución tecnológica orientada al monitoreo de seguridad.

Asimismo, adopta un enfoque descriptivo, en tanto busca analizar el comportamiento de distintos tipos de ataques a partir de eventos observables en logs, y evaluar la capacidad de detección de un sistema SIEM frente a dichos escenarios.

3.2 Diseño de la investigación

El diseño metodológico combina dos enfoques complementarios:

- Implementación en entorno controlado:

Se desarrolla una arquitectura de monitoreo basada en el análisis automatizado de registros, utilizando herramientas open source integradas en un pipeline de procesamiento de eventos.

- Análisis de casos de estudio:

Se analizan incidentes reales de ciberseguridad con el objetivo de identificar eventos generados durante el ataque y evaluar en qué medida podrían ser detectados mediante la correlación de logs.

Este enfoque permite relacionar la implementación técnica con escenarios reales, facilitando la validación de la hipótesis planteada.

3.3 Metodología de análisis de ataques

Para cada caso de estudio, se realiza un análisis basado en la reconstrucción de la secuencia de eventos generados durante el ataque.

Este análisis incluye:

- Identificación de las acciones realizadas por el atacante.
- Determinación de los eventos generados en cada etapa (autenticación, red, aplicación, sistema).
- Asociación de estos eventos con posibles fuentes de logs.
- Evaluación de la posibilidad de detección mediante reglas y correlación de eventos.

A partir de este proceso, se determina si el ataque presenta señales detectables en etapas tempranas y si estas podrían ser utilizadas por un sistema SIEM para su identificación.

3.4 Criterios de evaluación

La evaluación se realiza en función de la capacidad del sistema para identificar eventos relevantes dentro del flujo de un ataque.

Los principales criterios considerados son:

- Detección de eventos: capacidad de identificar actividades sospechosas a partir de logs.
- Correlación de eventos: posibilidad de relacionar múltiples eventos para reconstruir un patrón de ataque.
- Disponibilidad de registros: existencia de logs suficientes para detectar el incidente.
- Tiempo de detección: estimación del momento en el que el ataque podría haber sido identificado.

Estos criterios permiten evaluar el alcance del sistema en distintos escenarios y determinar su efectividad.

3.5 Variables de estudio

La variable principal del estudio es la implementación de un sistema automatizado de monitoreo de seguridad basado en el análisis de registros.

Las variables observadas incluyen:

- Capacidad de recolección de logs desde múltiples fuentes.
- Capacidad de procesamiento y normalización de eventos.
- Capacidad de detección de patrones sospechosos.
- Tiempo de detección de incidentes.
- Impacto potencial del ataque en función del momento de detección.

3.6 Instrumentos

Los instrumentos utilizados corresponden a los componentes que integran la arquitectura del sistema implementado.

La infraestructura se despliega mediante contenedores Docker y está compuesta por:

- **syslog-ng**: recolección centralizada de logs.
- **Logstash**: procesamiento y normalización de eventos.
- **Elasticsearch**: almacenamiento e indexación de registros.
- **PostgreSQL**: almacenamiento estructurado de alertas.
- **n8n**: automatización del análisis y respuesta.
- **React**: visualización de eventos y métricas de seguridad.
- **Vite**: herramienta de construcción y entorno de desarrollo rápido para aplicaciones frontend.
- **TailwindCSS**: framework de estilos utilitario para el diseño de interfaces responsivas.
- **FastAPI**: framework backend para la construcción de APIs REST de alto rendimiento.
- **Python**: lenguaje de programación utilizado para la lógica del sistema y procesamiento de datos.
- **WebSocket**: protocolo de comunicación en tiempo real para la transmisión de eventos.
- **Docker**: plataforma de contenedorización para el despliegue aislado de servicios.
- **Docker Compose**: herramienta para la orquestación y gestión de múltiples contenedores.
- **N8N (Workflows)**: motor de automatización para la orquestación de procesos y respuesta ante eventos.

CAPITULO 4: Implementación SIEM

El presente capítulo describe la implementación de la arquitectura de monitoreo de seguridad desarrollada para el trabajo. El sistema fue concebido como un entorno de laboratorio orientado a la recolección, procesamiento y análisis automatizado de registros de seguridad, con el objetivo de evaluar la capacidad de un SIEM para detectar patrones de actividad sospechosa a partir de eventos observables en distintas capas de la infraestructura.

La implementación se apoya en una arquitectura modular desplegada mediante contenedores, lo que permite integrar componentes especializados para la recepción de logs, su procesamiento, su almacenamiento y su posterior consulta. Este enfoque permite materializar los conceptos desarrollados en los capítulos previos y establecer una base funcional para la simulación y el análisis de los casos de estudio considerados en la investigación.

4.1 Arquitectura Propuesta e Implementada

4.1.1 Descripción General

La arquitectura implementada responde a un esquema de procesamiento por etapas, en el cual cada componente cumple una función específica dentro del flujo general del sistema. En términos generales, el sistema recibe registros generados por distintos hosts, centraliza dichos eventos, los procesa para facilitar su interpretación y los almacena en estructuras adecuadas para su consulta posterior.

Dentro de esta arquitectura, syslog-ng cumple la función de recepción centralizada de logs, actuando como punto de entrada para los registros remotos generados por los equipos monitoreados. Posteriormente, Logstash interviene en la etapa de ingesta y procesamiento, tomando los archivos generados por el colector y preparándolos para su indexación. Elasticsearch se utiliza como motor de almacenamiento e indexación de eventos, permitiendo búsquedas y consultas sobre los registros procesados. De forma complementaria, PostgreSQL se emplea para el almacenamiento estructurado de alertas, usuarios y reglas de detección.

Sobre esta base se incorpora una capa de aplicación desarrollada con FastAPI, cuya función es exponer servicios para la consulta de alertas, autenticación, obtención de información resumida del sistema y ejecución de simulaciones. A su vez, el sistema cuenta con una interfaz desarrollada en React, orientada a la visualización de alertas, la consulta de casos y la interacción con el entorno de pruebas.

4.1.2 Componentes y Sus Roles

Los componentes que integran la arquitectura implementada pueden organizarse según su función dentro del sistema. En la capa de recolección se ubica syslog-ng, encargado de recibir registros de red y organizarlos en archivos por host y por tipo de evento. Esta función resulta esencial para concentrar la información proveniente de distintas fuentes y establecer un punto único de entrada al sistema.

En la capa de procesamiento se encuentra Logstash, cuya función consiste en leer los registros generados por syslog-ng, aplicar un tratamiento básico sobre ellos y enviarlos al motor de indexación. Esta etapa permite estructurar la información y prepararla para su posterior análisis. En la capa de almacenamiento se integran dos componentes con finalidades distintas. Por un lado, Elasticsearch se utiliza para indexar eventos y facilitar búsquedas sobre grandes volúmenes de registros. Por otro, PostgreSQL permite mantener un almacenamiento estructurado de alertas, reglas de detección y usuarios del sistema.

En la capa de aplicación se encuentra el backend desarrollado con FastAPI. Este componente cumple la función de articular el acceso a la información estructurada del sistema, exponer operaciones vinculadas a alertas y autenticación, y ofrecer un mecanismo de simulación de eventos para pruebas controladas.

En la capa de presentación se ubica el frontend desarrollado con React y Vite, cuya finalidad es proporcionar una interfaz de consulta y visualización del estado general del entorno monitoreado.

4.1.3 Red Docker y Aislamiento

La infraestructura del sistema se despliega mediante Docker Compose, lo que permite definir los distintos servicios que integran la solución dentro de una red lógica común. Este enfoque facilita la reproducción del entorno de laboratorio, la separación funcional entre componentes y la administración de dependencias entre servicios.

La red definida para la solución permite la comunicación entre los contenedores encargados de la recolección, el procesamiento, el almacenamiento y la exposición de datos. De esta forma, los componentes pueden interactuar de manera controlada, sin requerir una instalación manual individual sobre el sistema anfitrión. Asimismo, el uso de volúmenes persistentes permite conservar la información asociada a bases de datos y almacenamiento de eventos entre ejecuciones del entorno.

Desde el punto de vista metodológico, este esquema de despliegue resulta adecuado para un laboratorio académico, ya que favorece la consistencia del entorno, simplifica la puesta en marcha de la arquitectura y permite aislar de manera lógica los distintos elementos que participan en el pipeline de monitoreo.

4.1.4 Flujo de Datos del Sistema

El flujo de datos implementado en la arquitectura puede describirse como una secuencia ordenada de etapas. En primer lugar, los hosts o contenedores que forman parte del entorno generan eventos de sistema o de seguridad. Estos registros son enviados hacia el colector central y recibidos por syslog-ng, que los organiza en archivos dentro del entorno compartido.

En una segunda etapa, Logstash toma dichos archivos como fuente de entrada, procesa los registros y los deriva al sistema de indexación. Una vez indexados en Elasticsearch, los eventos pueden ser consultados y analizados según distintos criterios temporales o de contenido.

De forma complementaria, las alertas generadas dentro del sistema son almacenadas en PostgreSQL junto con información asociada a su categoría, severidad, origen y estado. Sobre esta información estructurada opera el backend, que permite tanto la consulta como la gestión de alertas dentro del entorno de laboratorio.

Finalmente, la interfaz desarrollada en React consume los datos expuestos por la API y permite visualizar el estado del sistema, consultar alertas recientes y ejecutar simulaciones de eventos alineadas con los casos estudiados en la tesis. Este flujo permite cubrir las etapas de recolección, procesamiento, almacenamiento y consulta, en concordancia con los objetivos definidos para la arquitectura implementada.

4.2 Implementación Técnica

4.2.1 Infraestructura Docker

La implementación técnica del sistema se apoya en un archivo de orquestación que define los servicios necesarios para el funcionamiento del entorno. Dentro de esta infraestructura se incluyen contenedores destinados a PostgreSQL, Elasticsearch, Logstash, syslog-ng, backend, frontend y clientes de prueba. Asimismo, se contemplan servicios asociados a n8n, integrados como parte del despliegue general.

La inclusión de clientes de prueba dentro de la red permite disponer de fuentes controladas para la generación de eventos, lo que resulta útil para la simulación de escenarios y la validación conceptual del flujo de monitoreo. En conjunto, esta infraestructura permite reproducir un entorno de laboratorio coherente con los objetivos del trabajo y con el enfoque experimental adoptado.

4.2.2 Pipeline de Ingesta: syslog-ng y Logstash

La etapa de ingesta constituye el núcleo operativo del sistema implementado. En primer lugar, syslog-ng recibe eventos remotos mediante el protocolo configurado

para el entorno y los almacena en archivos organizados por host. Esta organización permite separar registros de autenticación y registros generales del sistema, facilitando su posterior tratamiento.

Sobre esos archivos opera Logstash, el cual actúa como componente de lectura y procesamiento de eventos. A través de su configuración, el sistema toma como entrada los registros almacenados por syslog-ng y los envía a Elasticsearch. Aunque el pipeline implementado es deliberadamente acotado, resulta suficiente para representar la lógica básica de una arquitectura SIEM orientada al análisis de registros en un entorno controlado.

La combinación de ambos componentes permite materializar el proceso de centralización e ingesta de logs, que constituye una de las capacidades fundamentales requeridas por la investigación.

4.2.3 Almacenamiento de Eventos

El almacenamiento de la información dentro del sistema se resuelve mediante dos mecanismos complementarios. Los eventos procesados son derivados a Elasticsearch, donde quedan indexados para su consulta posterior. Esta decisión permite disponer de un repositorio orientado a búsquedas y análisis sobre registros históricos, lo que resulta adecuado para el tratamiento de eventos de seguridad.

En paralelo, PostgreSQL se utiliza para almacenar información estructurada asociada al funcionamiento del sistema. En particular, el esquema implementado contempla tablas para alertas, reglas de detección y usuarios. Esta estructura permite conservar información relevante sobre los eventos detectados, su clasificación, su estado de gestión y los elementos necesarios para la interacción con la aplicación.

La separación entre almacenamiento de eventos indexados y almacenamiento estructurado de alertas responde a una lógica funcional clara: mientras Elasticsearch se orienta al manejo de registros, PostgreSQL organiza la información operativa asociada a la gestión del sistema.

4.2.4 Automatización y Detección de Eventos

La detección de eventos dentro del entorno implementado se apoya en reglas y patrones definidos para distintos tipos de actividad sospechosa. El sistema contempla categorías asociadas a intentos fallidos de autenticación, uso indebido de privilegios, escaneos y escenarios específicos vinculados con los casos de estudio considerados en la tesis.

Dentro de este esquema, el backend incorpora un módulo de simulación que permite generar eventos representativos de distintos tipos de incidente. Entre ellos se incluyen escenarios generales de laboratorio y casos alineados con patrones de comportamiento observables en RENAPER y Equifax. Esta capacidad permite evaluar, dentro de un entorno controlado, cómo el sistema registra y estructura eventos que podrían ser utilizados para la detección temprana de comportamientos anómalos.

Por otra parte, la arquitectura contempla la incorporación de mecanismos de automatización mediante n8n. Sin embargo, dado que los flujos concretos de dicha herramienta no se encuentran completamente evidenciados en el repositorio, su mención debe entenderse como parte de la arquitectura prevista para ampliar las capacidades de orquestación y respuesta, y no como una funcionalidad plenamente validada en la implementación actual.

4.2.5 Visualización de Eventos y Métricas

La visualización del sistema se realiza principalmente a través de una interfaz desarrollada en React, la cual permite consultar alertas, observar información resumida del entorno y acceder a los casos de estudio incorporados dentro del laboratorio. Esta interfaz constituye la capa de interacción principal con el sistema implementado y cumple una función relevante desde el punto de vista demostrativo y de análisis.

El frontend se conecta al backend mediante la API desarrollada en FastAPI, lo que permite recuperar información asociada a alertas, estados y simulaciones. De este

modo, la arquitectura incorpora una capa de presentación que facilita la interpretación de los eventos registrados y la exploración de los escenarios considerados en la investigación.

En conjunto, la implementación desarrollada permite disponer de una arquitectura funcional de laboratorio orientada al análisis automatizado de registros de seguridad. Si bien algunas capacidades permanecen en un estado de integración parcial o prevista, el sistema implementado resulta suficiente para sustentar la simulación de escenarios, la centralización de eventos y el análisis conceptual del alcance de un SIEM frente a distintos tipos de incidente.

CAPÍTULO 5: Análisis de los casos

Este capítulo desarrolla el análisis técnico de los casos de estudio seleccionados, reconstruyendo la secuencia de eventos de cada incidente e identificando los logs potencialmente observables, con el fin de evaluar en qué medida un sistema SIEM podría detectar y mitigar cada escenario.

5.1 Caso 1: RENAPER (Argentina, 2021)

5.1.1 Descripción técnica del ataque

El incidente de seguridad asociado al Registro Nacional de las Personas (RENAPER) se produjo a partir del uso indebido de credenciales legítimas pertenecientes a un organismo con acceso autorizado al sistema.

A través de estas credenciales, el atacante accedió al servicio de validación del Sistema de Identidad Digital (SID), el cual permite consultar información asociada a un número de documento (DNI). Este servicio devuelve datos personales sensibles, incluyendo nombre, dirección, fecha de nacimiento e imagen del ciudadano.

El acceso se realizó mediante una conexión VPN habilitada, lo que indica que el atacante no explotó una vulnerabilidad técnica en la infraestructura, sino que utilizó credenciales válidas para realizar consultas al sistema.

Durante el incidente, se realizaron múltiples solicitudes al servicio en un intervalo de tiempo reducido, lo que permitió extraer información de distintos individuos. Parte de estos datos fue posteriormente publicada en redes sociales.

5.1.2 Timeline del ataque

A partir de la información disponible, el incidente puede representarse como una secuencia de eventos:

1. Obtención o acceso a credenciales válidas.
2. Establecimiento de conexión a través de VPN autorizada.
3. Acceso al servicio de validación (SID).
4. Ejecución de múltiples consultas a partir de distintos DNI.
5. Obtención de datos personales e imágenes.
6. Publicación de la información obtenida.

5.1.3 Eventos generados (logs)

Durante la ejecución del ataque, se generan múltiples eventos observables en distintos niveles de la infraestructura:

- Logs de autenticación (VPN / sistema)
- Inicio de sesión con credenciales válidas
- Registro de dirección IP de origen
- Logs de aplicación (SID)
- Solicitudes de consulta por DNI
- Frecuencia de requests
- Identificación del usuario autenticado
- Logs de base de datos
- Consultas repetitivas a registros de ciudadanos
- Acceso a información sensible

- Logs de red
- Tráfico hacia el servicio de validación

Estos eventos, aunque individuales, representan señales que pueden ser utilizadas para detectar comportamientos anómalos cuando se analizan en conjunto.

5.1.4 Análisis de detección

Desde el punto de vista del monitoreo de seguridad, el comportamiento observado presenta características detectables:

- Alta frecuencia de consultas en un período corto
- Acceso repetitivo a información sensible
- Uso intensivo de un servicio por un mismo usuario
- Posible desviación respecto al comportamiento normal del sistema

Si bien cada evento individual puede ser considerado válido, la secuencia completa evidencia un patrón de uso anómalo.

5.1.5 Detección mediante SIEM

Un sistema SIEM podría detectar este comportamiento mediante la correlación de eventos provenientes de distintas fuentes.

Por ejemplo:

- Correlación entre autenticación y volumen de consultas
- Identificación de umbrales de requests por usuario
- Detección de accesos repetitivos a datos sensibles
- Análisis de comportamiento por ventana de tiempo

A través de reglas de detección, sería posible generar alertas ante patrones de uso que excedan los valores normales del sistema.

5.1.6 Evaluación del caso

El incidente analizado presenta múltiples eventos observables y correlacionables dentro de logs de autenticación, aplicación y base de datos.

En este contexto, la implementación de un sistema SIEM podría haber permitido detectar el comportamiento anómalo en etapas tempranas, reduciendo el volumen de información expuesta.

Por lo tanto, este caso se considera potencialmente mitigable mediante mecanismos de monitoreo y correlación de eventos, en línea con la hipótesis planteada.

5.2 Caso 2: Equifax (Estados Unidos, 2017)

5.2.1 Descripción técnica del ataque

El incidente de seguridad de Equifax se originó a partir de la explotación de una vulnerabilidad conocida en el framework Apache Struts (CVE-2017-5638), presente en una aplicación web expuesta a internet.

A través de esta vulnerabilidad, los atacantes lograron ejecutar código de forma remota en el servidor comprometido. A partir de este acceso inicial, desplegaron mecanismos de persistencia, como web shells, que les permitieron mantener acceso al sistema.

Posteriormente, los atacantes obtuvieron credenciales internas y realizaron movimientos laterales dentro de la infraestructura, accediendo a múltiples sistemas y bases de datos. Durante este proceso, realizaron consultas a datos sensibles de forma sostenida durante un período prolongado.

El ataque se mantuvo activo durante aproximadamente 76 días, lo que permitió la exfiltración de información personal de aproximadamente 147 millones de personas.

5.2.2 Timeline del ataque

El incidente puede representarse como la siguiente secuencia de eventos:

1. Explotación de vulnerabilidad en aplicación web (Apache Struts).
2. Ejecución remota de comandos en el servidor.
3. Instalación de mecanismos de persistencia (web shell).
4. Obtención de credenciales internas.
5. Movimiento lateral hacia otros sistemas.
6. Acceso a bases de datos sensibles.
7. Extracción de información durante un período prolongado.

5.2.3 Eventos generados (logs)

Durante el ataque, se generan múltiples eventos observables en distintos niveles:

- **Logs de aplicación web**

- Requests maliciosos hacia endpoints vulnerables
- Patrones asociados a explotación (payloads)

- **Logs de sistema**

- Ejecución de comandos en el servidor
- Creación o modificación de archivos (web shells)

- **Logs de autenticación**

- Uso de credenciales internas
- Accesos a sistemas desde hosts comprometidos

- **Logs de red**

- Conexiones entre sistemas internos (lateral movement)
- Tráfico de salida asociado a exfiltración

- **Logs de base de datos**

- Consultas a gran volumen de registros
- Acceso a información sensible

Estos eventos permiten reconstruir el comportamiento del atacante a lo largo del tiempo.

5.2.4 Análisis de detección

El ataque presenta múltiples etapas con eventos detectables:

- Explotación inicial mediante patrones anómalos en requests web
- Ejecución de comandos en servidores expuestos
- Actividad inusual de autenticación
- Movimiento lateral entre sistemas
- Consultas masivas a bases de datos

A diferencia de ataques de corta duración, este incidente se caracteriza por su persistencia en el tiempo, lo que genera una gran cantidad de eventos correlacionables.

5.2.5 Detección mediante SIEM

Un sistema SIEM podría detectar este tipo de ataque mediante la correlación de eventos en distintas etapas:

- Identificación de patrones de explotación en logs de aplicación
- Correlación entre ejecución de comandos y cambios en el sistema
- Detección de accesos internos anómalos
- Identificación de movimiento lateral
- Detección de consultas masivas o accesos inusuales a bases de datos

Además, la persistencia del ataque incrementa la probabilidad de detección, ya que permite observar patrones repetitivos en el tiempo.

5.2.6 Evaluación del caso

El incidente de Equifax presenta múltiples eventos detectables en diferentes capas de la infraestructura, incluyendo aplicación, sistema, red y base de datos.

La duración del ataque y la cantidad de eventos generados aumentan significativamente la posibilidad de detección mediante mecanismos de monitoreo basados en logs y correlación de eventos.

En este contexto, la implementación de un sistema SIEM podría haber permitido identificar el ataque en etapas tempranas, reduciendo el tiempo de permanencia del atacante dentro del sistema y, en consecuencia, el volumen de información comprometida.

Por lo tanto, este caso se considera **potencialmente mitigable mediante el uso de un sistema SIEM**, en línea con la hipótesis planteada.

5.3 Caso 3: Stuxnet (2010)

5.3.1 Descripción técnica del ataque

Stuxnet fue un malware altamente sofisticado diseñado para atacar sistemas industriales, específicamente infraestructuras de control utilizadas en el programa nuclear iraní.

El código malicioso se propagaba a través de múltiples vectores, incluyendo dispositivos USB y redes internas, aprovechando diversas vulnerabilidades en sistemas Windows. Una vez dentro de la infraestructura, el malware permanecía inactivo hasta identificar entornos específicos que utilizaran software de control industrial Siemens STEP7.

Al detectar este tipo de sistema, Stuxnet modificaba la lógica de los controladores programables (PLC), alterando el funcionamiento de las centrifugadoras utilizadas para el enriquecimiento de uranio. Estas modificaciones provocaban variaciones

en la velocidad de operación de los equipos, generando desgaste y fallas progresivas.

De forma paralela, el malware interceptaba las señales enviadas a los sistemas de monitoreo, mostrando valores normales a los operadores. Este mecanismo de ocultamiento permitía que el ataque se ejecutara sin ser detectado durante períodos prolongados.

5.3.2 Timeline del ataque

El ataque puede representarse como la siguiente secuencia:

1. Propagación del malware a través de dispositivos USB o redes internas.
2. Infección de sistemas Windows dentro de la infraestructura.
3. Búsqueda de entornos con software industrial específico (STEP7).
4. Interacción con controladores PLC.
5. Modificación de la lógica de control de las centrifugadoras.
6. Alteración del funcionamiento físico de los equipos.
7. Ocultamiento de la actividad mediante manipulación de datos de monitoreo.

5.3.3 Eventos generados (logs)

A diferencia de los casos anteriores, los eventos generados presentan características particulares:

- **Logs de sistema (Windows)**

- Ejecución de código malicioso
- Modificación de archivos y procesos

- **Eventos de red interna**

- Comunicación entre sistemas comprometidos
- Propagación lateral dentro de la red
- **Eventos en sistemas industriales (PLC/SCADA)**
 - Cambios en la lógica de control
 - Alteración de parámetros operativos

Sin embargo, gran parte de estos eventos no se registran en sistemas tradicionales de logs IT o no son fácilmente accesibles desde plataformas convencionales.

5.3.4 Análisis de detección

El ataque presenta una baja visibilidad desde el punto de vista del monitoreo tradicional:

- Uso de múltiples vulnerabilidades y técnicas avanzadas
- Ejecución dentro de redes internas aisladas
- Interacción directa con sistemas industriales
- Manipulación de datos de monitoreo para ocultar actividad

A diferencia de los otros casos, no se observan patrones claros de comportamiento repetitivo en logs tradicionales que permitan detectar el ataque de forma temprana.

5.3.5 Detección mediante SIEM

Un sistema SIEM tradicional, basado en logs de entornos IT, presenta limitaciones para detectar este tipo de ataque.

Si bien podrían observarse algunos eventos en sistemas Windows o en la red interna, la falta de visibilidad sobre los sistemas industriales y la manipulación de datos de monitoreo dificultan la generación de alertas confiables.

Además, la activación selectiva del malware —solo en entornos específicos— reduce la cantidad de eventos detectables, limitando la capacidad de correlación.

5.3.6 Evaluación del caso

El caso Stuxnet presenta características que lo diferencian de los ataques tradicionales en entornos IT, principalmente por su enfoque en sistemas industriales y su capacidad de ocultamiento.

La baja visibilidad de los eventos relevantes y la dependencia de sistemas específicos dificultan su detección mediante mecanismos basados únicamente en logs convencionales.

En este contexto, un sistema SIEM tradicional no resultaría suficiente para detectar el ataque en etapas tempranas, ya que los eventos críticos no son fácilmente observables ni correlacionables dentro de las fuentes habituales.

Por lo tanto, este caso se considera **no prevenible de forma directa mediante un sistema SIEM**, lo que permite contrastar los límites de este enfoque frente a distintos tipos de incidentes.

CAPÍTULO 6: Resultados y análisis

El presente capítulo expone los resultados obtenidos a partir de la instrumentación y medición operativa del sistema implementado en el entorno de laboratorio, con el objetivo de evaluar su comportamiento frente a los casos de estudio analizados en la investigación. Se incorporaron mediciones reales sobre el backend y la gestión de alertas, permitiendo obtener valores concretos de tiempo de detección, reconocimiento y resolución dentro del laboratorio implementado.

Los resultados presentados se basan en la ejecución controlada de pruebas sobre la arquitectura desarrollada, utilizando eventos simulados alineados con los patrones analizados para los casos RENAPER y Equifax, así como un escenario de referencia adicional de fuerza bruta utilizado para validar el comportamiento general del sistema. En el caso de Stuxnet, debido a las limitaciones de visibilidad ya expuestas en capítulos anteriores, no fue posible obtener métricas operativas equivalentes dentro del entorno actual.

6.1 Consideraciones sobre los resultados

Los resultados obtenidos en esta etapa corresponden a mediciones reales realizadas sobre la arquitectura instrumentada del sistema, particularmente en la capa de aplicación y gestión de alertas implementada en el backend. Para ello se incorporaron marcas temporales asociadas al momento de generación del evento, creación de la alerta, reconocimiento de la alerta por parte del sistema y resolución de la misma, permitiendo calcular métricas operativas concretas.

No obstante, resulta necesario aclarar que estas mediciones corresponden a una instrumentación mínima viable del entorno de laboratorio. En la implementación actual, los eventos generados por el simulador son registrados directamente en la base de datos a través del backend, por lo que las métricas obtenidas representan el comportamiento real del sistema en su estado actual de integración, pero no incluyen todavía la latencia total de un pipeline SIEM completo con tránsito efectivo por syslog-ng, Logstash y Elasticsearch.

En este sentido, los resultados permiten evaluar de manera válida el desempeño del sistema en la etapa de gestión de alertas y respuesta dentro del laboratorio, aunque no deben interpretarse como una medición exhaustiva del rendimiento de una arquitectura SIEM plenamente integrada de extremo a extremo.

6.2 Metodología de simulación

Con el objetivo de reemplazar los valores simulados por métricas observables, se instrumentó el sistema incorporando timestamps específicos en el ciclo de vida de cada alerta generada. A partir de esta modificación, se registraron los siguientes momentos:

- Evento generado: instante en el que el simulador produce el evento representativo del escenario de ataque.
- Alerta creada: instante en el que el backend registra la alerta correspondiente dentro del sistema.

- Alerta reconocida: instante en el que la alerta cambia a un estado de análisis o reconocimiento.
- Alerta resuelta: instante en el que la alerta es marcada como resuelta.

Sobre esta base, se calcularon las siguientes métricas:

- MTTD (Mean Time To Detect): tiempo transcurrido entre la generación del evento y la creación de la alerta.
- MTTA (Mean Time To Acknowledge): tiempo transcurrido entre la creación de la alerta y su reconocimiento por parte del sistema o del operador.
- MTTR (Mean Time To Respond): tiempo transcurrido entre la creación de la alerta y su resolución.

Para la obtención de resultados se ejecutaron quince alertas de prueba distribuidas en tres categorías operativas:

- Cinco alertas asociadas a consulta masiva, utilizadas como representación del caso RENAPER;
- Cinco alertas asociadas a exploit web, utilizadas como representación del caso Equifax;
- Cinco alertas asociadas a fuerza bruta, utilizadas como escenario de validación general del sistema.

Posteriormente, todas las alertas fueron llevadas a estado de investigación y luego a estado resuelto, permitiendo relevar valores efectivos para las tres métricas mencionadas.

6.3 Métricas Operativas

A partir de las mediciones realizadas, el sistema registró los siguientes valores promedio globales:

- MTTD: 0,00 segundos
- MTTA: 2,10 segundos
- MTTR: 4,21 segundos

El valor de MTTD igual a 0,00 segundos se explica por la arquitectura actual del laboratorio: el simulador genera el evento y el backend registra la alerta dentro del mismo flujo de ejecución, sin atravesar todavía un pipeline externo completo de recolección, procesamiento e indexación. Por esta razón, el tiempo de detección dentro de esta instrumentación mínima resulta prácticamente inmediato.

Por su parte, el MTTA promedio de 2,10 segundos refleja el tiempo requerido para reconocer operativamente la alerta una vez registrada, mientras que el MTTR promedio de 4,21 segundos representa el tiempo total necesario para resolverla dentro del entorno de prueba.

Estos valores evidencian que, en el estado actual del sistema, la detección y gestión de eventos resulta ágil dentro de la capa de aplicación implementada. Sin embargo, también ponen de manifiesto que el comportamiento temporal medido corresponde a un entorno de laboratorio controlado y a una integración aún parcial del pipeline SIEM.

6.4 Resultados de la simulación

6.4.1 Caso RENAPER

Para este caso se utilizaron alertas de la categoría consulta masiva, orientadas a representar un patrón de accesos repetitivos a información sensible dentro de un intervalo acotado de tiempo. Este escenario reproduce conceptualmente el comportamiento anómalo observado en el caso RENAPER, donde el uso de credenciales válidas permitió realizar múltiples consultas sobre datos personales.

En las cinco ejecuciones realizadas para esta categoría, el sistema registró los siguientes promedios:

- MTTD: 0,00 segundos
- MTTA: 2,12 segundos
- MTTR: 4,23 segundos

Los resultados muestran que, una vez generado el evento dentro del backend instrumentado, la alerta es registrada de manera inmediata y puede ser reconocida

y resuelta en pocos segundos dentro del entorno de laboratorio. Desde el punto de vista analítico, esto respalda la hipótesis de que un patrón como el observado en RENAPER puede ser detectado y gestionado a partir de reglas basadas en volumen de consultas, frecuencia y comportamiento por ventana temporal.

En consecuencia, el caso RENAPER continúa considerándose potencialmente mitigable mediante un sistema SIEM, siempre que exista visibilidad suficiente sobre las autenticaciones, consultas a servicios y accesos a información sensible.

6.4.2 Caso Equifax

Para este caso se utilizaron alertas de la categoría exploit web, diseñadas para representar eventos asociados a explotación de aplicaciones expuestas, en línea con el vector inicial del incidente de Equifax. Si bien el caso real involucró múltiples etapas adicionales —como persistencia, movimiento lateral y acceso a bases de datos—, el escenario medido dentro del laboratorio se concentró en la generación y tratamiento del evento de explotación inicial.

En las cinco ejecuciones realizadas para esta categoría, el sistema registró los siguientes promedios:

- MTTD: 0,00 segundos
- MTTA: 2,09 segundos
- MTTR: 4,20 segundos

Estos valores muestran un comportamiento operativo similar al observado en el caso RENAPER, con tiempos reducidos de gestión dentro del backend instrumentado. La rápida creación de la alerta y su posterior tratamiento indican que el sistema resulta apto para gestionar eventos compatibles con patrones conocidos de ataque web.

No obstante, debe señalarse que la complejidad del caso Equifax excede el evento inicial de explotación. Por ello, si bien la medición obtenida resulta útil para validar la capacidad del sistema frente a la etapa inicial del ataque, una evaluación completa requeriría incorporar correlación entre múltiples fuentes —aplicación,

sistema, red y base de datos— con tránsito efectivo por el pipeline SIEM completo. Aun así, los resultados obtenidos sostienen la interpretación de que un entorno con visibilidad suficiente y reglas adecuadas habría incrementado las posibilidades de detección temprana del incidente.

6.4.3 Caso Stuxnet

A diferencia de los casos anteriores, el escenario asociado a Stuxnet no pudo ser medido mediante métricas operativas equivalentes dentro del entorno implementado. Esto se debe a que el sistema actual no incorpora fuentes específicas de entornos industriales, ni cuenta con visibilidad directa sobre PLC, SCADA o mecanismos de alteración de lógica de control.

En consecuencia, no fue posible obtener valores comparables de MTDD, MTTA o MTTR para este caso a partir de la instrumentación actual. Lejos de constituir una omisión metodológica, esta imposibilidad de medición confirma una de las conclusiones centrales del trabajo: la efectividad de un SIEM depende directamente de la observabilidad disponible sobre el entorno monitoreado.

Desde esta perspectiva, la ausencia de métricas operativas para Stuxnet constituye un resultado consistente con el análisis desarrollado en los capítulos previos. El ataque no solo presenta baja visibilidad desde logs tradicionales, sino que además compromete sistemas donde gran parte de los eventos relevantes no queda registrada en las fuentes IT convencionales sobre las que opera la arquitectura implementada.

Por lo tanto, el caso Stuxnet se mantiene como un escenario no prevenible de forma directa mediante el sistema desarrollado en su configuración actual, y evidencia los límites de una arquitectura SIEM basada principalmente en logs tradicionales de infraestructura IT.

6.5 Tabla comparativa de resultados

A continuación se presenta una síntesis comparativa de los resultados obtenidos para los escenarios medidos y para el caso de baja visibilidad.

Caso / Categoría	Eventos medidos	MTTD (s)	MTTA (s)	MTTR (s)	Observaciones
RENAPER	5	0,00	2,12	4,23	Detección inmediata dentro del backend instrumentado; patrón compatible con umbrales de uso y consultas repetitivas
Equifax	5	0,00	2,09	4,20	Detección inmediata del evento inicial de explotación; no incluye aún correlación multi-fuente completa
Fuerza bruta	5	0,00	2,10	4,20	Escenario auxiliar utilizado para validar estabilidad operativa de las métricas
Stuxnet	No aplicable	No medible	No medible	No medible	Falta de visibilidad sobre eventos industriales y ausencia de fuentes ICS/SCADA en el laboratorio

De manera complementaria, el promedio global de las quince alertas medidas fue el siguiente:

Métrica global	Valor promedio
MTTD	0,00 s
MTTA	2,10 s
MTTR	4,21 s

6.6 Análisis de resultados

Los resultados obtenidos permiten establecer varias observaciones relevantes respecto del comportamiento del sistema implementado y del alcance de la hipótesis planteada en la investigación.

En primer lugar, las mediciones realizadas evidencian que, dentro del entorno de laboratorio instrumentado, el sistema presenta una capacidad de registro y gestión

rápida de alertas. Tanto en el escenario representativo de RENAPER como en el de Equifax, el backend fue capaz de registrar la alerta de manera inmediata y de completar el ciclo básico de reconocimiento y resolución en pocos segundos. Esto demuestra que la arquitectura implementada resulta funcional como base para el monitoreo y tratamiento de eventos dentro de un entorno controlado.

En segundo lugar, los resultados confirman que los casos RENAPER y Equifax presentan patrones de ataque que pueden ser representados mediante eventos observables y tratables por el sistema. En ambos escenarios existen acciones que dejan rastros compatibles con reglas de detección: consultas repetitivas a información sensible, patrones de explotación web, actividad anómala de autenticación o accesos sospechosos. Desde esta perspectiva, los resultados obtenidos respaldan la idea de que un sistema SIEM puede contribuir a la detección temprana y a la mitigación del incidente cuando la infraestructura provee visibilidad suficiente sobre el comportamiento del atacante.

Sin embargo, también resulta imprescindible interpretar los valores medidos con criterio metodológico. El MTTD nulo observado en las pruebas no implica que toda arquitectura SIEM detecte incidentes de forma instantánea, sino que responde a la forma en que el laboratorio se encuentra instrumentado actualmente. Dado que el simulador y el registro de alertas operan dentro del mismo backend, la detección ocurre prácticamente sin latencia intermedia. Por lo tanto, este valor debe entenderse como un resultado válido para la configuración actual, aunque no extrapolable de manera directa a una arquitectura SIEM completa con múltiples componentes desacoplados y procesamiento distribuido.

En tercer lugar, el caso Stuxnet confirma la principal limitación del enfoque implementado. La ausencia de métricas operativas medibles para este caso no responde a una falla puntual de implementación, sino a una restricción estructural vinculada con la observabilidad. Cuando los eventos relevantes no están disponibles en fuentes tradicionales de logs, la capacidad de correlación del SIEM se reduce de forma significativa. Este resultado refuerza el planteo teórico desarrollado previamente: la eficacia de un sistema SIEM depende no solo de sus

reglas o de su velocidad de procesamiento, sino de la existencia de señales observables dentro del entorno monitoreado.

En conjunto, los resultados permiten sostener que la arquitectura implementada constituye una base válida para analizar el comportamiento de un sistema SIEM en escenarios con distinta disponibilidad de eventos. Los casos RENAPER y Equifax muestran que, ante ataques con trazas observables, el sistema puede detectar y gestionar actividad sospechosa en tiempos reducidos dentro del laboratorio. Por el contrario, el caso Stuxnet evidencia que, frente a escenarios con baja visibilidad o dependencia de fuentes industriales especializadas, la capacidad de detección resulta limitada o directamente insuficiente.

CAPÍTULO 7: Conclusiones y trabajos futuros

Este capítulo sintetiza las conclusiones derivadas del desarrollo teórico, la implementación técnica y el análisis de resultados, validando la hipótesis planteada e identificando las principales limitaciones del trabajo y las posibles líneas de continuidad futura.

7.1 Conclusiones

El presente trabajo tuvo como propósito analizar el alcance de una arquitectura de monitoreo de seguridad basada en el análisis automatizado de registros, con el objetivo de evaluar en qué medida un sistema SIEM puede contribuir a la detección temprana y mitigación de incidentes de ciberseguridad.

A lo largo del desarrollo se diseñó e implementó un entorno de laboratorio orientado a la recolección, procesamiento, almacenamiento y análisis de eventos de seguridad, integrando componentes de ingesta, indexación, almacenamiento estructurado, visualización y gestión de alertas. Sobre esta base, se analizaron tres casos de estudio representativos —RENAPER, Equifax y Stuxnet— seleccionados por presentar distintos niveles de visibilidad, correlación y observabilidad dentro de una infraestructura monitoreada.

Los resultados obtenidos permiten concluir que la efectividad de un sistema SIEM depende de manera directa de la disponibilidad de eventos observables y de la posibilidad de correlacionarlos dentro del entorno analizado. En los casos RENAPER y Equifax, el comportamiento del atacante genera rastros compatibles con fuentes tradicionales de logs de autenticación, aplicación, sistema, red o acceso a datos. Esto permite identificar patrones anómalos y construir reglas de detección capaces de generar alertas oportunas frente a comportamientos sospechosos.

En el entorno instrumentado, las pruebas realizadas permitieron medir tiempos operativos reales sobre la gestión de alertas, obteniéndose valores bajos de reconocimiento y resolución dentro de la capa de aplicación implementada. Si bien estas mediciones corresponden a una instrumentación mínima viable del laboratorio y no representan aún la latencia completa de un pipeline SIEM de extremo a extremo, sí evidencian que la arquitectura desarrollada resulta funcional como base para la detección y tratamiento de eventos dentro de un entorno controlado.

En contraste, el caso Stuxnet expone una limitación estructural del enfoque. La ausencia de visibilidad suficiente sobre sistemas industriales, junto con la manipulación de señales de monitoreo y la baja exposición de eventos relevantes en logs IT convencionales, restringe de forma significativa la capacidad de detección del sistema implementado. En este sentido, el trabajo confirma que un SIEM tradicional, apoyado principalmente en registros de infraestructura informática convencional, no resulta suficiente para abordar de manera directa ataques cuya lógica operativa se desarrolla fuera del dominio de observación del sistema.

En términos generales, el estudio permite sostener que los sistemas SIEM constituyen una herramienta relevante para fortalecer la detección temprana de incidentes en escenarios donde existe generación suficiente de eventos observables y posibilidad de correlación entre fuentes heterogéneas. Sin embargo, también demuestra que su alcance no es absoluto, sino que se encuentra

condicionado por el nivel de observabilidad del entorno, la calidad de los datos recolectados y el grado de integración de las distintas capas del sistema de monitoreo.

Por lo tanto, la principal conclusión del trabajo es que un sistema SIEM puede contribuir de manera efectiva a reducir los tiempos de detección y mejorar la capacidad de respuesta frente a determinados tipos de ataques, pero su desempeño se ve limitado cuando los eventos críticos no son visibles, no se registran en fuentes accesibles o requieren telemetría especializada que excede el alcance de un entorno IT tradicional.

7.2 Validación final de la hipótesis

La hipótesis planteada en el presente trabajo establece que, de los tres incidentes analizados, al menos dos podrían haberse evitado o mitigado significativamente mediante la implementación de un sistema SIEM, mientras que uno de ellos no sería prevenible de forma directa a través de este tipo de solución.

A partir del análisis técnico desarrollado y de los resultados obtenidos en el entorno de laboratorio, esta hipótesis puede considerarse validada.

En primer lugar, los casos RENAPER y Equifax presentan condiciones que favorecen la detección mediante mecanismos de monitoreo basados en logs. En ambos escenarios, las acciones del atacante producen eventos observables en distintas capas de la infraestructura, tales como autenticaciones, consultas repetitivas a servicios, patrones de explotación web, actividad inusual sobre sistemas y accesos a datos sensibles. La posibilidad de correlacionar estos eventos permite identificar comportamientos anómalos dentro de ventanas temporales acotadas y, en consecuencia, generar alertas en etapas tempranas del incidente.

En el caso RENAPER, el uso intensivo de credenciales válidas para realizar consultas repetitivas a información sensible constituye un patrón susceptible de ser detectado mediante reglas basadas en volumen, frecuencia y comportamiento por usuario. En el caso Equifax, la presencia de eventos asociados a explotación

inicial, actividad persistente y acceso anómalo a recursos internos muestra que un entorno con mayor visibilidad y correlación podría haber incrementado significativamente la probabilidad de detección temprana, reduciendo el tiempo de permanencia del atacante dentro de la infraestructura.

Por el contrario, el caso Stuxnet presenta un escenario cualitativamente distinto. Su ejecución sobre sistemas industriales específicos, la limitada disponibilidad de logs convencionales y la capacidad del malware para ocultar o manipular señales de monitoreo reducen drásticamente la posibilidad de detección mediante un SIEM tradicional. En este contexto, la ausencia de eventos claramente observables dentro de las fuentes monitoreadas impide establecer mecanismos de correlación suficientes para una detección temprana confiable.

En consecuencia, la evidencia reunida permite afirmar que la hipótesis del trabajo se cumple: los casos RENAPER y Equifax corresponden a escenarios potencialmente mitigables mediante una arquitectura SIEM adecuadamente implementada, mientras que Stuxnet representa un caso cuyo nivel de visibilidad insuficiente limita de forma directa la efectividad de este tipo de solución.

De este modo, la validación final de la hipótesis no solo confirma el valor del SIEM como herramienta de detección y apoyo a la mitigación, sino que también delimita con mayor precisión su alcance real. El trabajo demuestra que la utilidad de estos sistemas no depende exclusivamente de su capacidad tecnológica, sino de la relación entre el tipo de ataque, la disponibilidad de registros y la profundidad de observación que puede alcanzarse sobre el entorno monitoreado.

7.3 Limitaciones del trabajo

El presente trabajo presenta ciertas limitaciones que deben ser consideradas al interpretar los resultados obtenidos.

En primer lugar, el análisis de los casos se basa en la reconstrucción de eventos a partir de información pública, lo que implica que no se dispone de acceso directo a los logs originales generados durante los incidentes.

En segundo lugar, la validación se realizó mediante simulaciones dentro de un entorno controlado, lo que implica que los eventos generados representan una aproximación al comportamiento real de los ataques.

Asimismo, la arquitectura implementada corresponde a un entorno de laboratorio, por lo que no contempla la complejidad y escala de infraestructuras productivas.

7.4 Trabajos futuros

A partir de los resultados obtenidos, se identifican diversas líneas de trabajo que podrían ampliar el alcance del presente estudio.

En primer lugar, se propone la incorporación de fuentes de datos adicionales, especialmente aquellas provenientes de entornos industriales (ICS/SCADA), con el objetivo de mejorar la visibilidad en escenarios como el caso Stuxnet.

En segundo lugar, se plantea la integración de técnicas avanzadas de detección, como el uso de modelos de aprendizaje automático, que permitan identificar patrones de comportamiento anómalos más complejos.

También resulta relevante explorar la integración de sistemas SIEM con plataformas SOAR, con el fin de automatizar no solo la detección, sino también la respuesta ante incidentes.

Por último, se propone la validación del sistema en entornos más cercanos a producción, incorporando mayores volúmenes de datos y escenarios más complejos, lo que permitiría evaluar su comportamiento en condiciones reales.

7.5. Consideraciones Éticas

El sistema desarrollado en este proyecto está destinado exclusivamente a su utilización en **entornos de laboratorio o infraestructuras controladas con fines académicos**. Su uso debe realizarse únicamente sobre sistemas cuya monitorización haya sido previamente autorizada.

Los registros analizados pueden contener información como **direcciones IP, nombres de host o identificadores de usuario**, por lo que su tratamiento debe respetar principios de **confidencialidad y minimización de datos**, almacenando únicamente la información necesaria para el análisis de seguridad.

En el contexto de informes académicos o presentaciones, cualquier dato que permita identificar sistemas o usuarios reales deberá ser **anonimizado o pseudonimizado**.

Asimismo, las pruebas del sistema deben realizarse mediante **escenarios simulados**, evitando cualquier actividad que pueda afectar sistemas productivos o redes externas sin autorización.

16. Referencias

Manzoor, J., et al. (2024). *Evaluating security and performance of open-source SIEM systems*. PLOS ONE.

Sinha, A. (2024). *Challenges and best practices for integrating Security Orchestration, Automation, and Response (SOAR) platforms in cloud environments*. CEUR Workshop Proceedings.

Enhancing Cyber Resilience: Convergence of SIEM, SOAR and AI in 2024. (2024). *International Journal of Cybersecurity & Emerging Trends*.

Ismail, M. (2025). *Toward Robust Security Orchestration and Automated Incident Response Using Agentic-LLM*. Information (MDPI).

Pereira, V. R. (2023). *Cyber-attack detection and response using open-source tools*. National College of Ireland.

Elastic N.V. (2024). *Elasticsearch Reference Documentation*.

<https://www.elastic.co/guide/en/elasticsearch/reference/current/index.html>

Elastic N.V. (2024). *Logstash Reference Documentation*.

<https://www.elastic.co/guide/en/logstash/current/index.html>

Docker Inc. (2024). *Docker Documentation*. <https://docs.docker.com/>

Docker Inc. (2024). *Docker Compose Documentation*.

<https://docs.docker.com/compose/>

syslog-ng Community. (2024). *syslog-ng Administrator Guide*.

<https://www.syslog-ng.com/technical-documents/doc/syslog-ng-open-source-edition>

n8n GmbH. (2024). *n8n Documentation*. <https://docs.n8n.io/>

Grafana Labs. (2024). *Grafana Documentation*.

<https://grafana.com/docs/grafana/latest/>

PostgreSQL Global Development Group. (2024). *PostgreSQL Documentation*.

<https://www.postgresql.org/docs/>

Anexo A — Esquema SQL (Base de Datos)

El sistema utiliza **PostgreSQL** para el almacenamiento estructurado de alertas de seguridad y reglas de detección. La base de datos permite registrar eventos detectados, gestionar su estado y definir reglas utilizadas por el sistema para identificar comportamientos sospechosos dentro de la infraestructura monitoreada.

Tabla: alertas

La tabla **alertas** almacena los eventos de seguridad detectados por el sistema de monitoreo. Cada registro representa una alerta generada a partir del análisis de logs o del cumplimiento de una regla de detección.

```
CREATE TABLE alertas (
```

```
    id SERIAL PRIMARY KEY,
```

```
fecha TIMESTAMP DEFAULT CURRENT_TIMESTAMP,  
  
severidad VARCHAR(20) NOT NULL,  
  
categoria VARCHAR(50) NOT NULL,  
  
ip_origen INET,  
  
host_objetivo VARCHAR(255),  
  
cantidad_eventos INTEGER DEFAULT 1,  
  
descripcion TEXT,  
  
log_crudo TEXT,  
  
estado VARCHAR(20) DEFAULT 'nueva',  
  
asignado_a VARCHAR(100),  
  
notas TEXT,  
  
resuelto_en TIMESTAMP  
  
);
```

Descripción de campos principales:

Campo	Descripción
id	Identificador único de la alerta
fecha	Fecha y hora de generación de la alerta
severidad	Nivel de criticidad del evento detectado
categoria	Tipo de evento de seguridad
ip_origen	Dirección IP asociada al evento
host_objetivo	Sistema o servicio afectado

Campo	Descripción
cantidad_eventos	Número de eventos que generaron la alerta
descripcion	Descripción del evento detectado
log_crudo	Registro original del log asociado
estado	Estado de la alerta (nueva, en análisis, resuelta)
asignado_a	Analista responsable de la revisión
notas	Comentarios o información adicional
resuelto_en	Fecha de resolución del incidente

Tabla: reglas_deteccion

La tabla **reglas_deteccion** define los patrones utilizados por el sistema para identificar posibles incidentes de seguridad dentro de los registros analizados.

```
CREATE TABLE reglas_deteccion (  
    id SERIAL PRIMARY KEY,  
    nombre VARCHAR(200) NOT NULL,  
    descripcion TEXT,  
    patron TEXT NOT NULL,  
    severidad VARCHAR(20) NOT NULL,  
    umbral INTEGER DEFAULT 1,  
    ventana_tiempo INTEGER DEFAULT 300,  
    habilitada BOOLEAN DEFAULT true,
```

creada_en TIMESTAMP DEFAULT CURRENT_TIMESTAMP,

actualizada_en TIMESTAMP DEFAULT CURRENT_TIMESTAMP

);

Descripción de campos principales:

Campo	Descripción
id	Identificador único de la regla
nombre	Nombre de la regla de detección
descripcion	Descripción del tipo de evento que detecta
patron	Patrón o expresión utilizada para identificar eventos
severidad	Nivel de criticidad asignado a la alerta generada
umbral	Cantidad mínima de eventos para generar alerta
ventana_tiempo	Intervalo de tiempo considerado para evaluar el umbral
habilitada	Indica si la regla se encuentra activa
creada_en	Fecha de creación de la regla
actualizada_en	Fecha de última modificación

Anexo B — Cronograma de Implementación

Módulo	Título	Duración	Objetivos	Entregables
1	Fundamentos y arquitectura	2 h	Diseño de componentes y flujos	Diagrama lógico
2	Ingesta y normalización	3 h	syslog-ng + Logstash funcionando	Logs en Elasticsearch
3	Reglas de detección	3 h	SSH BF y FIM operativos	Alertas JSON hacia n8n
4	Orquestación con n8n	3 h	Workflow activo con PostgreSQL	Workflow JSON exportado
6	Documentación y ajustes	2 h	README y guía completos	Paquete didáctico

Anexo C — Implementación del flujo automatizado en n8n

En este anexo se presenta el detalle técnico de los nodos que componen el flujo automatizado implementado en n8n para la detección de eventos de seguridad, aplicación de reglas, generación de alertas y respuesta inicial. El objetivo de este apartado es complementar la descripción funcional desarrollada en el cuerpo principal del trabajo, incorporando el código y la lógica utilizada en cada etapa del proceso. La secuencia del workflow comprende la ejecución periódica del flujo, la consulta de reglas de detección almacenadas en la base de datos, la lectura y

extracción de contenido desde archivos de logs, el procesamiento de los eventos, la aplicación de reglas de correlación, el envío de notificaciones y el almacenamiento persistente de las alertas generadas.

Anexo A.1. Nodo Cronómetro 5 min

Este nodo cumple la función de disparador temporal del flujo. Su propósito es ejecutar automáticamente el proceso de detección cada cinco minutos, permitiendo que la revisión de logs y la evaluación de reglas se realicen de manera periódica sin intervención manual. De esta manera, se establece un mecanismo continuo de monitoreo, adecuado para un escenario de laboratorio orientado a la detección temprana de incidentes.

Anexo A.2. Nodo GetRules

Este nodo realiza una consulta a la base de datos PostgreSQL con el fin de recuperar las reglas de detección activas. Estas reglas son utilizadas posteriormente por el nodo de correlación para determinar si los eventos extraídos de los logs alcanzan los umbrales definidos y deben transformarse en alertas de seguridad. La consulta empleada es la siguiente:

```
SELECT * FROM reglas_deteccion WHERE habilitada = true;
```

La finalidad de esta operación es obtener dinámicamente las reglas vigentes, evitando que la lógica de detección quede fija en el flujo y permitiendo administrar los criterios desde la base de datos.

Anexo A.3. Nodo Read Logs

Este nodo se encarga de leer los archivos de logs desde el sistema de archivos. Su función es incorporar al flujo el contenido bruto que posteriormente será procesado. En términos operativos, actúa como la etapa de ingestión inicial,

permitiendo que n8n acceda a los registros generados por los distintos componentes monitoreados.

Anexo A.4. Nodo Extract from File

Este nodo tiene como objetivo extraer el texto contenido en los archivos leídos previamente, transformándolo en un formato utilizable por los nodos posteriores. Su incorporación resultó relevante para normalizar la entrada y evitar pérdidas de información durante el procesamiento, ya que convierte el contenido del archivo en texto estructurado accesible desde el flujo.

Anexo A.5. Nodo Parse Logs

Este nodo procesa el contenido textual de los archivos de logs y lo transforma en eventos estructurados. Su lógica consiste en recorrer cada entrada recibida, separar el contenido por líneas, descartar líneas vacías, extraer la dirección IP cuando está presente y clasificar preliminarmente el evento según el contenido del mensaje. En particular, identifica eventos relacionados con fallos de autenticación cuando encuentra la cadena *Failed password*. El código implementado es el siguiente:

```
const items = $input.all();

const events = [];

for (const item of items) {
  const text = item.json.data;

  if (!text) continue;

  const lines = text.split('\n');
```

```
for (const line of lines) {  
  if (!line.trim()) continue;  
  
  const ipMatch = line.match(/\\b\\d{1,3}(?:\\.\\d{1,3}){3}\\b/);  
  
  events.push({  
    raw: line,  
    source_ip: ipMatch ? ipMatch[1] : null,  
    category: line.includes('Failed password') ? 'authentication_failure' : 'general',  
    event_time: new Date().toISOString()  
  });  
}  
}  
  
return events.map(e => ({ json: e }));
```

Desde el punto de vista funcional, este nodo cumple una tarea central dentro del flujo, ya que convierte registros no estructurados en objetos con atributos concretos, facilitando su posterior evaluación mediante reglas.

Anexo A.6. Nodo Apply rules

Este nodo aplica las reglas de detección recuperadas desde la base de datos sobre los eventos procesados por el nodo anterior. Para ello, toma los logs estructurados, recorre cada regla activa, construye una expresión regular a partir del patrón definido y verifica cuántos eventos coinciden. Si la cantidad de coincidencias alcanza o supera el umbral establecido, genera una alerta con información de contexto, incluyendo fecha, severidad, categoría, IP de origen, host objetivo, cantidad de eventos, descripción y log crudo asociado. El código utilizado es el siguiente:

```
const logs = $input.all().map(i => i.json);  
const rules = $('GetRules').all().map(i => i.json);
```

```
const alerts = [];  
  
for (const rule of rules) {  
  const re = new RegExp(rule.patron, 'i');  
  const matching = logs.filter(l => re.test(l.raw || ""));  
  
  if (matching.length >= rule.umbral) {  
    alerts.push({  
      fecha: new Date().toISOString(),  
      severidad: rule.severidad || 'media',  
      categoria: rule.nombre,  
      ip_origen: matching[0]?.source_ip || null,  
      host_objetivo: 'docker-siem',  
      cantidad_eventos: matching.length,  
      descripcion: `Regla ${rule.nombre} activada`,  
      log_crudo: matching[0]?.raw || ""  
    });  
  }  
}  
  
return alerts.map(a => ({ json: a }));
```

Este nodo representa el núcleo de la lógica de detección, ya que materializa el proceso de correlación entre eventos observados y criterios predefinidos, transformando actividad sospechosa en alertas concretas.

Anexo A.7. Nodo Send an Email

Este nodo realiza la notificación automática de las alertas detectadas mediante correo electrónico. Su propósito es generar una salida inmediata que permita advertir sobre la ocurrencia de un posible incidente sin necesidad de consultar

manualmente la base de datos o los dashboards. El cuerpo del mensaje fue definido en formato HTML para mejorar la legibilidad de la alerta recibida. La plantilla utilizada es la siguiente:

```
<h2><img alt="Warning icon" data-bbox="188 188 208 201"/> Alerta de Seguridad</h2>
```

```
<p><b>Severidad:</b> {{$json.severidad}}</p>
```

```
<p><b>Categoría:</b> {{$json.categoria}}</p>
```

```
<p><b>IP Origen:</b> {{$json.ip_origen || 'N/A'}}</p>
```

```
<p><b>Host:</b> {{$json.host_objetivo}}</p>
```

```
<p><b>Eventos:</b> {{$json.cantidad_eventos}}</p>
```

```
<p><b>Descripción:</b></p>
```

```
<p>{{$json.descripcion}}</p>
```

```
<p><b>Fecha:</b> {{$json.fecha}}</p>
```

La estructura del mensaje permite presentar en forma clara los datos principales de la alerta generada, facilitando una respuesta inicial rápida por parte del operador o administrador.

Anexo A.8. Nodo Store alerts

Este nodo tiene como función persistir las alertas generadas en la base de datos PostgreSQL. De esta manera, cada detección queda registrada para su posterior consulta, análisis o auditoría. La sentencia SQL utilizada inserta en la tabla alertas los campos producidos por el nodo de aplicación de reglas, incluyendo la severidad, categoría, IP de origen, cantidad de eventos, descripción, log crudo y estado inicial. El código implementado es el siguiente:

```
INSERT INTO alertas (  
    fecha,  
    severidad,
```

```
categoria,  
ip_origen,  
host_objetivo,  
cantidad_eventos,  
descripcion,  
log_crudo,  
estado  
) VALUES (  
    '{{json.fecha}}',  
    '{{json.severidad}}',  
    '{{json.categoria}}',  
    '{{ json.ip_origen ? `{{$json.ip_origen}` : 'NULL' }}::inet',  
    '{{json.host_objetivo}}',  
    '{{json.cantidad_eventos}}',  
    '{{json.descripcion.replace(/'/g, "'")}}',  
    '{{json.log_crudo.replace(/'/g, "'")}}',  
    'nueva'  
);
```

Este registro persistente resulta importante dentro de la arquitectura propuesta, ya que permite conservar trazabilidad sobre las detecciones realizadas y construir un historial de eventos de seguridad observados por el sistema.

Anexo A.9. Consideración general sobre el flujo

En conjunto, los nodos descritos conforman una cadena automatizada de procesamiento que permite ejecutar periódicamente la lectura de logs, estructurar eventos, compararlos contra reglas almacenadas en la base de datos, generar alertas cuando se cumplen determinadas condiciones, notificar al responsable y almacenar los resultados para análisis posterior. Esta implementación demuestra, a escala de laboratorio, cómo un flujo orquestado en n8n puede integrarse a una

arquitectura SIEM para reducir los tiempos de detección y respuesta ante eventos sospechosos.